Command-and-Control im Red Teaming: Technische Analyse des Sliver Frameworks

Projektarbeit

im Studiengang Angewandte Informatik
an der Dualen Hochschule Baden-Württemberg Mannheim

von
Gabriel Ralf Ricarte Lanz

Abgabedatum: 27.08.2026

Bearbeitungszeitraum	08.01.2026-27.08.2026
Matrikelnummer, Kurs	6613445, TINF24AI1
Ausbildungsfirma	ABB AG
Betreuer	Tran, Jake
Unterschrift Betreuer	_____

Sperrvermerk

Der Inhalt dieser Arbeit darf weder als Ganzes noch in Auszügen Personen außerhalb des Prüfungsprozesses und des Evaluationsverfahrens zugänglich gemacht werden, sofern keine anders lautende Genehmigung des Dualen Partners vorliegt.

Erklärung

Ich versichere hiermit, dass ich meine Bachelorarbeit (bzw. Projektarbeit oder Studienarbeit bzw. Hausarbeit) mit dem Thema: Command-and-Control im Red Teaming: Technische Analyse des Sliver Frameworks selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Ich versichere zudem, dass die eingereichte elektronische Fassung mit der gedruckten Fassung übereinstimmt.

Frankfurt am Main, den 27.08.2026

Ort, Datum	Unterschrift

Abstract

The present report focuses on the analysis of modern Command-and-Control (C2) frameworks in the context of Red Team operations. C2 infrastructures represent a core component of realistic attack simulations, as they enable the centralized control of compromised systems and the execution of post-exploitation activities. The work provides a technical examination of contemporary C2 frameworks, with a particular focus on the Sliver framework. In addition, established solutions such as Metasploit and Cobalt Strike are comparatively assessed to identify architectural differences, operational characteristics, and typical use cases. The results contribute to evaluating the suitability of modern C2 frameworks for penetration testing as a service offering within the Service Central Cyber-Security (SZC) department and provide a foundation for further investigations in the area of payload and communication obfuscation.

Zusammenfassung

Die in dieser Arbeit beschriebenen Tätigkeiten wurden im Rahmen der dritten Praxisphase bei ASEA Brown Boveri AG (ABB) durchgeführt. Der Praxiszeitraum erstreckte sich über die vereinbarte Dauer der dritten Praxisphase. Die Tätigkeiten fanden an den Standorten Frankfurt am Main und Mannheim statt und wurden in der Abteilung Process Automation Energy Industries (PAEN), konkret im Service Zentralbereich Cyber-Security (SZC), unter der fachlichen Anleitung des betrieblichen Betreuers Jake Tran durchgeführt.

Gegenstand dieser Praxisarbeit ist die Analyse moderner Command-and-Control-Infrastrukturen (C2) im Kontext von Red-Team-Operationen. Der Schwerpunkt liegt auf der technischen Betrachtung aktueller C2-Frameworks, wobei insbesondere das Framework Sliver detailliert analysiert wird. Ergänzend erfolgt eine vergleichende Einordnung weiterer verbreiteter Lösungen, darunter unter anderem Metasploit und Cobalt Strike, um Gemeinsamkeiten, Unterschiede sowie jeweilige Einsatzszenarien herauszuarbeiten.

Im Rahmen der Arbeit werden zentrale Aspekte moderner C2-Frameworks untersucht, darunter Architekturkonzepte, Kommunikationsmechanismen, Payload-Generierung sowie operative Punkte im Hinblick auf Stealth und OPSEC. Ziel ist es, ein fundiertes Verständnis für die Funktionsweise und den praktischen Einsatz dieser Infrastrukturen in realistischen Red-Team-Szenarien zu vermitteln.

Die Analyse zeigt zugleich, dass trotz fortschreitender Entwicklung moderner C2-Frameworks weiterhin Schwachstellen in Bezug auf Erkennbarkeit, Signaturbildung und Verhaltensanalyse bestehen. Diese Erkenntnisse verdeutlichen die Notwendigkeit zusätzlicher Maßnahmen zur Tarnung von Payloads und Kommunikationsmustern, insbesondere im Umfeld zunehmend leistungsfähiger Endpoint-Detection-and-Response-Systeme.

Inhaltsverzeichnis

Sperrvermerk **i**

Erklärung zur Eigenleistung **ii**

Inhaltsverzeichnis **v**

Abbildungsverzeichnis **vii**

Tabellenverzeichnis (Eigene Darstellung) **viii**

Abkürzungsverzeichnis **ix**

Überblick der Tätigkeiten der Praxisphasen **x**

1 Einleitung **1**
1.1 Ziel der Praxisarbeit 1
1.2 Einordnung von Command-and-Control (C2) im Red Teaming . 1
1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen 2

2 Grundlagen und gängige C2-Frameworks **3**
2.1 Command-and-Control (C2) – Grundkonzept 3
2.2 Kommunikation in C2-Frameworks 3
2.2.1 Kommunikationsmodelle 3
2.2.2 Architektur der C2-Kommunikation 4
2.3 Anforderungen an moderne C2-Frameworks 5
2.3.1 Stealth und OPSEC 5
2.3.2 Modularität 5
2.3.3 Umgehung von EDR/AV-Systemen 6
2.3.4 Flexibilität und Anpassungsfähigkeit 6
2.4 Überblick über gängige C2-Frameworks 6
2.4.1 Metasploit (MSF) 7
2.4.2 Cobalt Strike 7
2.4.3 Sliver 8

3 Methodik der Analyse von Sliver C2 **10**
3.1 Zielsetzung der Analyse 10
3.2 Analyseumgebung 11
3.3 Untersuchungsdesign 12
3.4 Analysekriterien 13
3.5 Ablauf der Experimente 15

4 Durchführung - Analyse des Sliver Frameworks **17**
4.1 Aufbau der Testumgebung 17
4.2 Einrichtung der Sliver Infrastruktur 17
4.3 Erstellung und Ausführung von Implantaten 17
4.4 Analyse der C2 Kommunikation 17
4.5 Analyse der Systemartefakte 17
4.6 Analyse der Detektion durch Elastic 17
4.7 Variation der Kommunikationsparameter 17

5 Ergebnisse **18**

6 Diskussion **19**
6.1 19

7 Fazit **20**

8 Ausblick **21**

Abbildungsverzeichnis

1 Cyber Kill Chain 2
2 Vereinfachte Kommunikationsstruktur eines C2-Frameworks . . . 4

Tabellenverzeichnis

1 Abkürzungsverzeichnis ix
2 Übersicht der Tätigkeiten während der Praxisphasen x
3 Übersicht der Analyseumgebung 12
4 Übersicht der verwendeten Analysekriterien 14

Abkürzungsverzeichnis

Abkürzung	Bedeutung
ABB	Asea Brown Boveri
AD	Active Directory
IT	Informations Technologie
C2	Command and Control
EDR	Endpoint Detection and Response
gRPC	Google Remote Procedure Call
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
IP	Internet Protocol
KRITIS	Kritische Infrastrukturen
NIS-2	Network and Information Systems Directive 2
OT	Operational Technology
DNS	Domain Name System
TLS	Transport Layer Security
OPSEC	Operational Security
PAEN	Process Automation Energy Industries
SZC	Service Zentralbereich Cyber-Security
SOC	Security Operations Center
SIEM	Security Information and Event Management

Tabelle 1: Abkürzungsverzeichnis

Überblick der Tätigkeiten der Praxisphasen

Nr.	Tätigkeit	Zeitraum	Praxisphase
1	Workshop der SZC Abteilung am Standort Frankfurt Praunheim	26.01.26-30.01.26	3
2	Themenbearbeitung: Social Engineering als Service Leistung	26.01.26-30.01.26	3
3	Themenbearbeitung: Command and Control Frameworks im Kontext von Penetration Tests	30.01.26 - 17.03.26	3

Tabelle 2: Übersicht der Tätigkeiten während der Praxisphasen

1 Einleitung

Die zunehmende Vernetzung industrieller Steuerungs- und Automatisierungssysteme führt zu einer wachsenden Angriffsfläche, insbesondere in sicherheitskritischen Betriebsumgebungen. Unternehmen, die im Bereich der Operational Technology (OT) und kritischer Infrastrukturen (KRITIS) tätig sind, stehen dabei vor der Herausforderung, sowohl regulatorische Anforderungen als auch steigende Bedrohungen durch hochentwickelte Angreifer zu adressieren. Vor diesem Hintergrund gewinnt die realistische Bewertung der eigenen Sicherheitsmaßnahmen zunehmend an Bedeutung.

1.1 Ziel der Praxisarbeit

Da ABB ein Anbieter und Integrator industrieller Automatisierungs- und Prozessleitsysteme ist, die in sicherheitskritischen Umgebungen eingesetzt werden, besteht die Notwendigkeit, Sicherheitsprüfungen über die reine Identifikation von Schwachstellen hinaus zu erweitern. Moderne Command-and-Control-Frameworks (C2) ermöglichen es, realistische Angreiferverhalten nachzubilden und die Wirksamkeit bestehender Sicherheitsmaßnahmen unter praxisnahen Bedingungen zu evaluieren.

Gegenstand dieser Praxisarbeit ist die technische Analyse moderner Command-and-Control-Frameworks (C2) im Kontext von Red-Team-Operationen. Im Fokus stehen dabei Architekturkonzepte, Kommunikationsmechanismen sowie operative Eigenschaften aktueller C2-Lösungen. Exemplarisch wird das Framework Sliver detailliert untersucht und mit weiteren etablierten Frameworks wie Metasploit und Cobalt Strike vergleichend eingeordnet.

Auf Basis dieser Analyse werden die Einsatzmöglichkeiten moderner C2-Frameworks im Rahmen realitätsnaher Angriffssimulationen bewertet. Dabei werden sowohl technische Kriterien als auch operationelle Gesichtspunkte wie Skalierbarkeit, Flexibilität und Stealth betrachtet. Die gewonnenen Erkenntnisse dienen als Grundlage für die Einordnung des praktischen Nutzens von C2-Infrastrukturen in professionellen Sicherheitsprüfungen und im Kontext angebotener Penetrationstests.

1.2 Einordnung von Command-and-Control (C2) im Red Teaming

Im Red Teaming stellt Command-and-Control eine zentrale Phase innerhalb der Cyber Kill Chain[1] dar. Nach erfolgreicher Kompromittierung eines Zielsystems ermöglicht eine C2-Infrastruktur die fortlaufende Steuerung kompromittierter Systeme, die Durchführung weiterer Aktionen sowie die Koordination komplexer Angriffsszenarien. Ohne eine funktionierende C2-Kommunikation ist eine nachhaltige und realitätsnahe Simulation moderner Angreifer nicht möglich.

Abbildung 1: Cyber Kill Chain

Im Gegensatz zu klassischen Penetrationstests, die häufig auf die Identifikation einzelner Schwachstellen fokussiert sind, zielt Red Teaming auf die Nachbildung vollständiger Angriffsabläufe ab. C2-Frameworks übernehmen hierbei die Rolle der zentralen Steuerungsinstanz und bilden die technische Grundlage für Post-Exploitation-Aktivitäten, laterale Bewegungen und persistente Zugriffsmechanismen. Ihre Ausgestaltung beeinflusst maßgeblich die Realitätsnähe und Aussagekraft einer Red-Team-Operation.

1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen

Mit dem Inkrafttreten der NIS-2-Richtlinie verschärfen sich die regulatorischen Anforderungen an Betreiber kritischer Infrastrukturen sowie an Unternehmen, die Dienstleistungen für diese bereitstellen. Insbesondere im OT- und KRITIS-Umfeld rücken Aspekte wie Angriffserkennung, Resilienz und kontinuierliche Sicherheitsbewertung stärker in den Fokus. ABB agiert in diesem Umfeld als Anbieter und Integrator industrieller Automatisierungs- und Prozessleitsysteme, deren Verfügbarkeit, Integrität und Sicherheit von zentraler Bedeutung sind.

Für den Service Zentralbereich Cyber-Security (SZC) ergibt sich daraus die Notwendigkeit, Sicherheitsprüfungen über rein technische Schwachstellenanalysen hinaus zu erweitern. Moderne C2-Frameworks ermöglichen es, realistische Angreiferverhalten nachzubilden und die Wirksamkeit bestehender Sicherheitsmaßnahmen unter praxisnahen Bedingungen zu evaluieren. Insbesondere im Rahmen von Penetrationstests als Serviceleistung bieten C2-Infrastrukturen die Möglichkeit, komplexe Angriffsszenarien kontrolliert zu simulieren und deren Auswirkungen auf IT- und OT-Umgebungen zu analysieren.

Die in dieser Praxisarbeit untersuchten C2-Frameworks leisten somit einen Beitrag zur Erhöhung der Aussagekraft von Sicherheitsprüfungen im regulierten Umfeld. Gleichzeitig bilden sie eine technische Grundlage für weiterführende Fragestellungen, etwa im Bereich der Tarnung von Payloads und Kommunikationsmustern, die im Kontext zunehmender Detektionsmechanismen an Bedeutung gewinnen.

2 Grundlagen und gängige C2-Frameworks

In diesem Kapitel werden zunächst die grundlegenden Konzepte von Command-and-Control (C2) erläutert und zentrale Anforderungen an moderne C2-Frameworks definiert. Darauf aufbauend erfolgt ein Überblick über verbreitete Frameworks wie Metasploit, Cobalt Strike und Sliver. Diese Einführung bildet die Grundlage für die vertiefte Analyse der Systeme im weiteren Verlauf der Arbeit.

2.1 Command-and-Control (C2) – Grundkonzept

Command-and-Control (C2) bezeichnet im Kontext von Cyberangriffen die Gesamtheit der Mechanismen und Infrastrukturen, die es einem Angreifer ermöglichen, kompromittierte Systeme zentral zu steuern. Nach erfolgreicher Kompromittierung eines Zielsystems dient die C2-Infrastruktur dazu, Befehle an Implantate oder Schadsoftware zu übermitteln, Rückmeldungen zu empfangen und weitere Aktionen zu koordinieren. Damit bildet sie die kommunikative Verbindung zwischen Angreifer und Zielsystem und stellt eine wesentliche Voraussetzung für nachhaltige und zielgerichtete Angriffe dar. [2]

2.2 Kommunikation in C2-Frameworks

Die Kommunikation zwischen kompromittierten Systemen und einer C2-Infrastruktur ist ein zentrales Element moderner Angriffsframeworks. Über diese Kommunikationskanäle werden Befehle vom Operator an kompromittierte Systeme übermittelt sowie Ergebnisse und Statusinformationen zurückgeführt. Ziel ist es dabei, die Datenübertragung zuverlässig und gleichzeitig möglichst unauffällig zu gestalten, um eine langfristige Kontrolle über betroffene Systeme aufrechtzuerhalten.

Um dies zu erreichen, orientieren sich viele Frameworks an legitimen Netzwerkprotokollen und passen ihr Kommunikationsverhalten an typische Netzwerkumgebungen an. Die Kommunikation kann dadurch in regulären Netzwerkverkehr eingebettet werden, was die Wahrscheinlichkeit einer Detektion reduziert.

2.2.1 Kommunikationsmodelle

Grundsätzlich lassen sich zwei zentrale Kommunikationsmodelle unterscheiden. Ein verbreiteter Ansatz ist das sogenannte *Beaconing*. Dabei baut ein kompromittiertes System in regelmäßigen oder adaptiven Intervallen selbstständig eine Verbindung zum C2-Server auf und fragt nach neuen Befehlen. Da hierbei

ausschließlich ausgehender Netzwerkverkehr entsteht, eignet sich dieses Modell besonders für Umgebungen mit restriktiven Firewall-Regeln.

Demgegenüber stehen *sessionbasierte* Modelle mit persistenten Verbindungen. Hier bleibt die Verbindung zwischen kompromittiertem System und C2-Server dauerhaft bestehen, wodurch eine nahezu unmittelbare Interaktion mit dem Zielsystem möglich wird. Diese Form der Kommunikation ermöglicht eine geringe Latenz bei der Befehlsausführung, kann jedoch aufgrund der permanenten Netzwerkverbindung leichter erkannt werden. [3]

2.2.2 Architektur der C2-Kommunikation

Unabhängig vom gewählten Kommunikationsmodell folgen viele C2-Frameworks einer zentralisierten Architektur. Der Operator interagiert über einen Client mit dem C2-Server, der als zentrale Vermittlungsstelle für die Kommunikation mit kompromittierten Systemen fungiert.

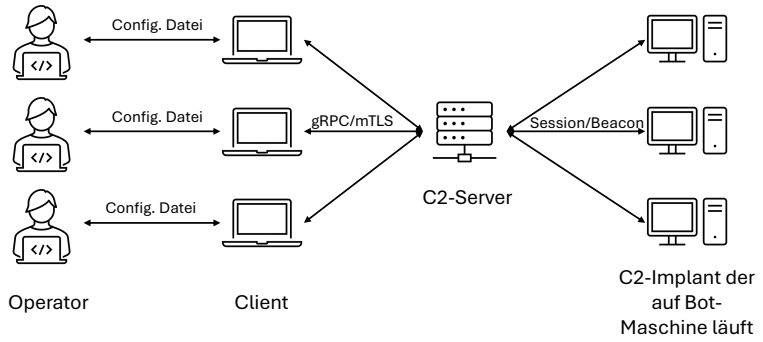

Abbildung 2: Vereinfachte Kommunikationsstruktur eines C2-Frameworks

Der C2-Server koordiniert dabei die gesamte Infrastruktur. Er nimmt Befehle vom Operator entgegen, verteilt diese an kompromittierte Systeme und sammelt deren Rückmeldungen. Da die kompromittierten Systeme in der Regel direkt mit dem Server kommunizieren, nimmt dieser eine zentrale Rolle innerhalb der Architektur ein.

Zur Umsetzung dieser Kommunikation nutzen C2-Frameworks verschiedene Netzwerkprotokolle. Besonders verbreitet ist TLS-geschützter HTTP(S)-Verkehr, da dieser in den meisten Netzwerken zugelassen ist und sich gut in regulären Web-Traffic integrieren lässt. Darüber hinaus kommen DNS-basierte Kommunikationsmechanismen zum Einsatz, die selbst in stark eingeschränkten Netzwerken eine grundlegende Datenübertragung ermöglichen können. Moderne Frameworks unterstützen zudem verschlüsselte Tunnelverfahren wie WireGuard, die eine robuste und performante Kommunikation bei gleichzeitig hohem Sicherheitsniveau ermöglichen.

Eine detaillierte Betrachtung dieser Kommunikationsmechanismen sowie deren operative Auswirkungen erfolgt in den nachfolgenden Abschnitten dieser Arbeit.

2.3 Anforderungen an moderne C2-Frameworks

Moderne Command-and-Control-Frameworks müssen eine Vielzahl technischer und operationeller Anforderungen erfüllen, um in realistischen Angriffsszenarien einsetzbar zu sein. Insbesondere im Kontext professioneller Sicherheitsprüfungen ist es erforderlich, dass C2-Infrastrukturen sowohl funktional leistungsfähig als auch flexibel an unterschiedliche Zielumgebungen anpassbar sind.

Die folgenden Kriterien stellen zentrale Anforderungen dar, die bei der Bewertung moderner Frameworks berücksichtigt werden müssen.

2.3.1 Stealth und OPSEC

Eine der wichtigsten Anforderungen an moderne C2-Frameworks ist ein hohes Maß an *Stealth*. Darunter versteht man die Fähigkeit, Kommunikations- und Laufzeitverhalten so zu gestalten, dass möglichst wenige Auffälligkeiten gegenüber Sicherheitsmechanismen entstehen.

In modernen IT- und insbesondere OT-Umgebungen werden Netzwerkverkehr, Prozessverhalten und Speicheraktivitäten zunehmend überwacht. Auffällige Muster können daher schnell zu einer Detektion führen.

Um diesem Risiko zu begegnen, müssen C2-Frameworks ihre Kommunikation und ihr Verhalten an die jeweilige Zielumgebung anpassen können. Dies umfasst beispielsweise die Nutzung legitimer Protokolle, die Integration in regulären Netzwerkverkehr sowie die Vermeidung auffälliger Prozess- oder Speicheraktivitäten. Darüber hinaus spielt eine sorgfältige Operational Security (OPSEC) eine entscheidende Rolle, um sowohl die Angriffsinfrastruktur als auch die durchgeführten Operationen vor Entdeckung zu schützen.

2.3.2 Modularität

Ein weiterer zentraler Aspekt moderner C2-Frameworks ist ihre Modularität. Ein modularer Aufbau ermöglicht es, verschiedene Komponenten wie Kommunikationsprotokolle, Verschlüsselungsmechanismen oder Implantattypen flexibel zu kombinieren und an spezifische Anforderungen anzupassen.

Dies erhöht nicht nur die Einsatzmöglichkeiten eines Frameworks, sondern erleichtert auch Wartung, Erweiterung und Weiterentwicklung der Infrastruktur.

2.3.3 Umgehung von EDR/AV-Systemen

Die zunehmende Verbreitung von Endpoint Detection and Response (EDR) sowie verhaltensbasierten Antivirenlösungen verschärft die Anforderungen an C2-Frameworks zusätzlich. Moderne Sicherheitsprodukte analysieren Prozesse, Speicherzugriffe und Netzwerkaktivitäten anhand heuristischer Modelle und Anomalieerkennung [4]. Vor diesem Hintergrund genügt es nicht, lediglich bekannte Signaturen zu vermeiden.

Vielmehr müssen Frameworks in der Lage sein, generische Erkennungsmerkmale zu minimieren. Dies betrifft sowohl die Art der Prozessausführung als auch das Kommunikationsverhalten. Die zuvor beschriebene Modularität unterstützt dies, da sie es ermöglicht, Mechanismen situationsabhängig anzupassen. Stealth, OPSEC und Modularität wirken somit zusammen, um die Wahrscheinlichkeit einer Detektion zu reduzieren und gleichzeitig realistische Angriffsszenarien zu ermöglichen.

2.3.4 Flexibilität und Anpassungsfähigkeit

Die genannten Anforderungen führen schließlich zu der übergeordneten Notwendigkeit der Flexibilität. IT- und insbesondere OT-Umgebungen unterscheiden sich erheblich hinsichtlich Netzwerkarchitektur, Sicherheitsniveau und regulatorischer Rahmenbedingungen.

Ein C2-Framework muss daher in der Lage sein, sich an unterschiedliche technische und organisatorische Gegebenheiten anzupassen. Dies umfasst sowohl die Unterstützung verschiedener Betriebssysteme und Kommunikationsprotokolle als auch die Möglichkeit, unterschiedliche Angriffsszenarien abzubilden.

Während in manchen Umgebungen eine kurzfristige, interaktive Analyse im Vordergrund steht, ist in anderen die Simulation langfristiger, persistenter Zugriffe entscheidend. Die Fähigkeit, Kommunikationsmodelle, Module und Einsatzparameter situationsabhängig zu konfigurieren, ist daher essenziell.

Gerade im regulierten Umfeld – etwa im Kontext von NIS-2 oder kritischen Infrastrukturen – ist zudem eine kontrollierte und nachvollziehbare Anpassungsfähigkeit von Bedeutung. Ein modernes C2-Framework muss daher nicht nur technisch leistungsfähig sein, sondern auch strukturiert einsetzbar, dokumentierbar und in bestehende Sicherheitsprozesse integrierbar bleiben.

2.4 Überblick über gängige C2-Frameworks

Im Folgenden werden drei verbreitete Command-and-Control-Frameworks vorgestellt und in ihren grundlegenden Eigenschaften eingeordnet: Metasploit, Cobalt Strike und Sliver. Die Auswahl deckt sowohl etablierte Open-Source-Werkzeuge als auch kommerzielle Red-Team-Lösungen ab und ermöglicht damit einen vergleichenden Blick auf unterschiedliche architektonische und operative Ansätze.

2.4.1 Metasploit (MSF)

Metasploit zählt zu den bekanntesten und am weitesten verbreiteten Frameworks in der Sicherheitscommunity. Ursprünglich als Plattform zur Entwicklung und Integration von Exploits konzipiert, hat es sich zu einem umfassenden Werkzeug für Penetrationstests und angriffsnahe Sicherheitsanalysen entwickelt. Das Framework stellt eine Vielzahl von Modulen bereit, darunter Exploits, Payloads, Encoder und Auxiliary-Komponenten, und deckt damit insbesondere die Phase der Initialkompromittierung strukturiert ab [5]. Command-and-Control-Funktionalitäten werden dabei primär über das **Meterpreter**-Modul realisiert.

Meterpreter ermöglicht eine interaktive, sessionbasierte Steuerung kompromittierter Systeme und unterstützt unter anderem Dateioperationen, Prozessinteraktionen sowie Speicherzugriffe. Die unmittelbare und latenzarme Ausführung von Befehlen ist insbesondere in klassischen Penetrationstests vorteilhaft, da sich Schwachstellen schnell validieren und Auswirkungen anschaulich demonstrieren lassen. Gleichzeitig ist zu berücksichtigen, dass persistente Sessions im Vergleich zu beaconing-basierten Modellen eine höhere Netzwerkauffälligkeit verursachen können. Dauerhafte Verbindungen oder interaktive Shells lassen sich in überwachten Umgebungen leichter identifizieren, insbesondere beim Einsatz moderner EDR- oder Netzwerküberwachungssysteme.

Im Unterschied zu speziell für langfristige Red-Team-Operationen entwickelten Frameworks liegt der Schwerpunkt von Metasploit weniger auf ausgeprägter OPSEC oder adaptiven Kommunikationsmodellen. Standardisierte Payloads und bekannte Artefakte können in produktiven Umgebungen vergleichsweise schnell erkannt werden. Zwar bestehen Anpassungs- und Erweiterungsmöglichkeiten, eine langfristig unauffällige C2-Infrastruktur war jedoch nicht primärer Designfokus des Frameworks.

Aus wirtschaftlicher Sicht ist zwischen dem frei verfügbaren Metasploit Framework und kommerziellen Varianten wie Metasploit Pro zu unterscheiden. Während das Open-Source-Framework kostenfrei genutzt werden kann, bieten kostenpflichtige Versionen zusätzliche Funktionen, etwa in den Bereichen automatisierte Berichterstellung, webbasierte Verwaltung und Projektmanagement. Für Organisationen ergibt sich daraus eine Abwägung zwischen funktionalem Mehrwert und den damit verbundenen Lizenzkosten.

2.4.2 Cobalt Strike

Cobalt Strike wurde gezielt für professionelle Red-Team-Operationen entwickelt und hat sich in den vergangenen Jahren als etablierte Lösung im kommerziellen Red-Team-Umfeld positioniert. Im Gegensatz zu Metasploit, dessen Ursprung in der Exploit-Integration liegt, steht bei Cobalt Strike die Durchführung fortgeschrittener Angriffe über mehrere Phasen der Kill Chain hinweg im Vordergrund. Der Schwerpunkt liegt damit weniger auf der initialen Schwachstellenausnutzung

als auf nachhaltiger Post-Exploitation und der kontrollierten Steuerung kompromittierter Systeme.

Zentrales Element der Architektur ist das sogenannte Beacon-Konzept. Anders als primär sessionbasierte Modelle setzt Cobalt Strike auf adaptive Beaconing-Kommunikation, die über verschiedene Transportmechanismen wie HTTP(S), DNS oder SMB erfolgen kann. Durch konfigurierbare Intervalle, verschleierte Datenstrukturen und flexible Infrastrukturparameter lässt sich das Kommunikationsverhalten an die jeweilige Zielumgebung anpassen. Im Vergleich zu persistenten Sessions reduziert dieses Modell die Netzwerkauffälligkeit und eignet sich besonders für längerfristige, realitätsnahe Angriffssimulationen.

Neben der Kommunikationsarchitektur bietet Cobalt Strike umfangreiche Funktionen zur Teamkoordination. Mehrere Operatoren können parallel auf einem Teamserver arbeiten, wodurch komplexe Angriffsszenarien strukturiert geplant und durchgeführt werden können. Ergänzt wird dies durch Mechanismen zur Verwaltung von Beacons, zur Durchführung von Post-Exploitation-Aktivitäten sowie zur Anpassung operativer Parameter. Diese Kombination aus technischer Flexibilität und organisatorischer Struktur macht das Framework besonders leistungsfähig im professionellen Einsatz.

Gleichzeitig ist zu berücksichtigen, dass Cobalt Strike aufgrund seiner weiten Verbreitung verstärkt im Fokus von Sicherheitsanbietern steht. Standardisierte Konfigurationen oder unzureichend angepasste Profile können daher ebenfalls zu einer schnellen Detektion führen. Hinzu kommt die kommerzielle Lizenzierung mit jährlichen Kosten, die je nach Nutzungsumfang und regionalen Rahmenbedingungen variieren können. Für Organisationen stellt sich daher die Frage nach dem Kosten-Nutzen-Verhältnis im Vergleich zu alternativen Lösungen.

2.4.3 Sliver

Sliver ist eine moderne Open-Source-basierte Command-and-Control-Lösung, die mit dem Ziel entwickelt wurde, flexible und modulare Red-Team-Infrastrukturen bereitzustellen. Im Unterschied zu Metasploit, das stärker auf Exploit-Integration ausgerichtet ist, und Cobalt Strike, das als kommerzielles Produkt vor allem koordinierte Red-Team-Operationen adressiert, positioniert sich Sliver als technisch leistungsfähige und zugleich kostenfreie Alternative mit infrastrukturellem Fokus.

Architektonisch unterstützt Sliver sowohl beaconing- als auch sessionbasierte Kommunikationsmodelle und bietet eine breite Auswahl an Transportprotokollen, darunter TLS-geschützter HTTP(S)-Verkehr, DNS sowie WireGuard-basierte Tunnel. Diese Vielfalt ermöglicht eine flexible Anpassung an unterschiedliche Netzwerkbedingungen und Sicherheitsanforderungen. Besonders hervorzuheben ist zudem die plattformübergreifende Ausrichtung des Frameworks, das Implantate für verschiedene Betriebssysteme generieren kann und damit heterogene Zielumgebungen adressiert.

Ein wesentliches Merkmal von Sliver ist die ausgeprägte Modularität seiner Architektur. Kommunikationsmechanismen, Implantate und Erweiterungen sind klar voneinander getrennt, wodurch sich einzelne Komponenten gezielt anpassen lassen. Darüber hinaus unterstützt Sliver den parallelen Betrieb mehrerer Operatoren innerhalb einer gemeinsamen Infrastruktur. Diese Eigenschaften rücken das Framework funktional näher an kommerzielle Lösungen heran, ohne an ein proprietäres Lizenzmodell gebunden zu sein.

Aus wirtschaftlicher Sicht stellt der Open-Source-Charakter einen wesentlichen Unterschied zu Cobalt Strike dar. Es fallen keine Lizenzkosten pro Operator oder Server an, was insbesondere für interne Sicherheitsabteilungen oder Organisationen mit mehreren Testumgebungen von Vorteil sein kann. Gleichzeitig liegt die Verantwortung für Wartung, Konfiguration und Infrastrukturdesign vollständig beim betreibenden Team, da kein kommerzieller Support im klassischen Sinne vorgesehen ist.

Im Vergleich zu Metasploit ist Sliver weniger auf die initiale Ausnutzung von Schwachstellen fokussiert, sondern stärker auf die strukturierte Steuerung und Verwaltung kompromittierter Systeme ausgelegt. Im Vergleich zu Cobalt Strike verfolgt es ähnliche konzeptionelle Ansätze hinsichtlich Beaconing und Teamfähigkeit, jedoch in einem offenen und anpassbaren Entwicklungsmodell.

Die detaillierte Analyse der Architektur, Kommunikationsmechanismen und operativen Eigenschaften von Sliver erfolgt im nachfolgenden Kapitel. Dort wird insbesondere untersucht, inwiefern das Framework die zuvor definierten Anforderungen an moderne C2-Infrastrukturen erfüllt.

3 Methodik der Analyse von Sliver C2

Im folgenden Kapitel wird die methodische Vorgehensweise zur Analyse des Command-and-Control-Frameworks Sliver beschrieben. Ziel der Untersuchung ist es, die technischen Eigenschaften sowie die operative Einsetzbarkeit des Frameworks in einer realitätsnahen Umgebung zu analysieren. Besonderes Augenmerk liegt dabei auf der Kommunikationsarchitektur, der Anpassungsfähigkeit der Infrastruktur sowie der Erkennbarkeit durch moderne Sicherheitsmechanismen.

Die Analyse erfolgt experimentell innerhalb einer kontrollierten Testumgebung, in der ein Sliver-Server betrieben und über einen Operator-Client gesteuert wird. Als Zielsystem dient eine Windows-basierte Maschine innerhalb eines Hack-The-Box-Pro-Labors[6], wodurch eine realitätsnahe Angriffs- und Verteidigungsumgebung simuliert werden kann. Zur Beobachtung sicherheitsrelevanter Ereignisse wird zusätzlich das Elastic Security Dashboard eingesetzt, welches Telemetriedaten des Zielsystems sowie Netzwerkaktivitäten visualisiert.

Im Rahmen der Untersuchung werden verschiedene Funktionen des Sliver-Frameworks systematisch ausgeführt und hinsichtlich ihres Verhaltens auf Netzwerk-, System- und Monitoringebene analysiert. Dazu gehören insbesondere die Generierung und Ausführung von Implantaten, der Aufbau von Command-and-Control-Verbindungen sowie die Variation unterschiedlicher Kommunikationsparameter. Die gewonnenen Beobachtungen bilden die Grundlage für die Bewertung des Frameworks im Hinblick auf die in Kapitel 2 definierten Anforderungen an moderne C2-Infrastrukturen.

3.1 Zielsetzung der Analyse

Ziel der vorliegenden Analyse ist die systematische Untersuchung des Command-and-Control-Frameworks Sliver hinsichtlich seiner technischen Eigenschaften und seiner Eignung für realistische Red-Team-Szenarien. Dabei wird insbesondere betrachtet, inwieweit das Framework die in Kapitel 2 definierten Anforderungen moderner C2-Infrastrukturen erfüllt.

Im Mittelpunkt der Untersuchung stehen dabei mehrere zentrale Fragestellungen. Zum einen wird analysiert, wie die Kommunikationsmechanismen des Frameworks umgesetzt sind und welche Netzwerkcharakteristika bei der Interaktion zwischen kompromittierten Systemen und der C2-Infrastruktur entstehen. Zum anderen wird untersucht, in welchem Umfang sich das Verhalten des Frameworks an unterschiedliche Einsatzbedingungen anpassen lässt, beispielsweise durch die Variation von Kommunikationsintervallen, Transportprotokollen oder Infrastrukturparametern.

Ein weiterer Schwerpunkt der Analyse liegt auf der Erkennbarkeit des Frameworks durch Sicherheitslösungen. Durch die Integration eines Elastic Security Dashboards in die Testumgebung kann beobachtet werden, welche Telemetrie-

daten während der Ausführung des Frameworks entstehen und ob typische Aktivitäten einer Command-and-Control-Kommunikation identifiziert werden können.

Die gewonnenen Erkenntnisse dienen dazu, das Sliver-Framework im Kontext moderner C2-Lösungen einzuordnen und seine Stärken sowie potenziellen Schwächen im Hinblick auf Stealth, Flexibilität und operative Einsatzfähigkeit zu bewerten.

3.2 Analyseumgebung

Die Untersuchung wurde in einer kontrollierten Laborumgebung durchgeführt, um reproduzierbare Ergebnisse zu gewährleisten und die Auswirkungen einzelner Analyseparameter gezielt beobachten zu können. Als Command-and-Control-Infrastruktur wurde ein Sliver-Server betrieben, der über einen dedizierten Operator-Client gesteuert wurde. Die Steuerung der Infrastruktur sowie die Generierung und Verwaltung von Implantaten erfolgte dabei über eine Kali-Linux-basierte Host-Maschine.

Als Zielsystem diente eine Windows-10-basierte Maschine innerhalb eines Hack The Box Pro Labs. Diese Umgebung stellt eine realitätsnahe Zielplattform dar, da sie typische Systemkonfigurationen sowie sicherheitsrelevante Monitoring-Komponenten beinhaltet. Die kompromittierte Maschine fungierte dabei als simuliertes Zielsystem, auf dem die generierten Sliver-Implantate ausgeführt wurden.

Zur Analyse möglicher Sicherheitsereignisse wurde das Elastic Security Dashboard eingesetzt. Dieses System aggregiert und visualisiert Telemetriedaten des Zielsystems, darunter Prozessereignisse, Netzwerkverbindungen sowie sicherheitsrelevante Systemaktivitäten. Dadurch konnte untersucht werden, in welchem Umfang die Aktivitäten des C2-Frameworks innerhalb einer überwachten Umgebung sichtbar werden.

Ergänzend wurde zur Analyse des Netzwerkverkehrs das Tool Wireshark verwendet. Damit konnten Kommunikationsmuster zwischen dem kompromittierten System und dem C2-Server auf Paketebene untersucht und hinsichtlich möglicher Auffälligkeiten analysiert werden. Die wesentlichen Komponenten der Analyseumgebung sind in Tabelle 3 zusammengefasst.

Nr.	Komponente	Beschreibung
1	Host-Maschine	Kali Linux System zur Steuerung des Sliver-Clients sowie zur Verwaltung der Analysewerkzeuge
2	Opfer-Maschine	Windows-10-System innerhalb eines Hack-The-Box-Pro-Labs, auf dem die generierten Implantate ausgeführt werden
3	Überwachungssystem	Elastic Security Dashboard zur Analyse von Telemetriedaten, Sicherheitsereignissen und Systemaktivitäten
4	Netzwerküberwachung	Wireshark zur Analyse des Netzwerkverkehrs zwischen Zielsystem und Command-and-Control-Infrastruktur

Tabelle 3: Übersicht der Analyseumgebung

Auf Basis dieser Infrastruktur werden im weiteren Verlauf der Arbeit verschiedene Experimente durchgeführt, um das Verhalten des Sliver-Frameworks hinsichtlich Kommunikationsmechanismen, Systemartefakten und möglicher Detektion durch Sicherheitslösungen zu untersuchen.

3.3 Untersuchungsdesign

Die Analyse des Sliver-Frameworks erfolgt in Form einer experimentellen Untersuchung innerhalb der zuvor beschriebenen Laborumgebung. Ziel ist es, zentrale Funktionen des Frameworks unter kontrollierten Bedingungen auszuführen und deren Auswirkungen auf Systemverhalten, Netzwerkkommunikation sowie sicherheitsrelevante Telemetriedaten zu beobachten.

Im Mittelpunkt der Untersuchung steht der praktische Einsatz des Frameworks zur Etablierung einer Command-and-Control-Kommunikation zwischen einem Operator-System und einem kompromittierten Zielsystem. Hierzu werden zunächst Implantate generiert und auf dem Zielsystem ausgeführt, wodurch eine Verbindung zum Sliver-Server hergestellt wird. Anschließend werden verschiedene Funktionen des Frameworks getestet, um deren Verhalten in einer überwachten Umgebung zu analysieren.

Die Experimente konzentrieren sich insbesondere auf die Analyse der Kommunikationsmechanismen des Frameworks. Dabei wird untersucht, welche Netzwerkcharakteristika während der Command-and-Control-Kommunikation entstehen und in welchem Umfang sich diese Aktivitäten in Netzwerk- und Sicherheitsmonitoring-Systemen nachvollziehen lassen. Ergänzend wird betrachtet, wie sich unterschiedliche Konfigurationsparameter, etwa Beacon-Intervalle oder verwendete Transportprotokolle, auf das Kommunikationsverhalten auswirken.

Zur Bewertung der Sichtbarkeit dieser Aktivitäten werden die während der Ex-

perimente erzeugten Telemetriedaten im Elastic Security Dashboard analysiert. Zusätzlich erfolgt eine Untersuchung des Netzwerkverkehrs mittels Wireshark, um Kommunikationsmuster zwischen dem kompromittierten System und der Command-and-Control-Infrastruktur auf Paketebene zu betrachten.

Die Analyse erfolgt schrittweise und orientiert sich an mehreren Untersuchungsschwerpunkten. Dazu gehören der Aufbau der Command-and-Control-Verbindung, die Analyse der resultierenden Netzwerkkommunikation, die Untersuchung möglicher Systemartefakte sowie die Bewertung der Erkennbarkeit durch Sicherheitslösungen. Auf diese Weise soll eine systematische Bewertung des Frameworks im Hinblick auf seine operative Einsetzbarkeit und seine Detektierbarkeit ermöglicht werden.

3.4 Analysekriterien

Die Bewertung des Sliver-Frameworks erfolgt anhand der in Kapitel 2 definierten Anforderungen an moderne Command-and-Control-Frameworks. Diese Kriterien dienen als analytischer Rahmen, um die technischen Eigenschaften sowie die operative Einsetzbarkeit des Frameworks systematisch zu untersuchen.

Im Mittelpunkt der Analyse stehen insbesondere vier zentrale Bewertungskategorien: die Kommunikationsmechanismen des Frameworks, dessen Stealth-Eigenschaften, die Modularität der Architektur sowie die Flexibilität der Infrastruktur. Diese Kriterien wurden ausgewählt, da sie wesentliche Faktoren für den praktischen Einsatz von C2-Frameworks in Red-Team-Operationen darstellen.

Ein erstes zentrales Kriterium bildet die Analyse der **Kommunikationsmechanismen**. Dabei wird untersucht, über welche Protokolle die Command-and-Control-Kommunikation erfolgt und welche Netzwerkcharakteristika während der Verbindung zwischen kompromittiertem System und C2-Infrastruktur entstehen. Besondere Aufmerksamkeit gilt hierbei der Frage, in welchem Umfang sich diese Kommunikationsmuster von regulärem Netzwerkverkehr unterscheiden.

Ein weiterer Untersuchungsschwerpunkt liegt auf den **Stealth-Eigenschaften** des Frameworks. Hierbei wird analysiert, wie auffällig die Aktivitäten des Frameworks innerhalb einer überwachten Umgebung erscheinen. Zu diesem Zweck werden Telemetriedaten des Zielsystems sowie Netzwerkereignisse im Elastic Security Dashboard ausgewertet, um mögliche Sicherheitsereignisse oder Detektionsmechanismen zu identifizieren.

Darüber hinaus wird die **Modularität** der Architektur betrachtet. Dabei wird untersucht, in welchem Umfang einzelne Komponenten des Frameworks, etwa Kommunikationsprotokolle oder Implantatkonfigurationen, flexibel kombiniert oder angepasst werden können.

Ein weiteres Bewertungskriterium stellt die **Flexibilität** der Infrastruktur dar. Hier wird analysiert, wie einfach sich das Framework an verschiedene Netzwerkum-

gebungen und Einsatzszenarien anpassen lässt. Dazu gehört beispielsweise die Variation von Kommunikationsparametern, die Nutzung unterschiedlicher Transportprotokolle oder die Anpassung von Beacon-Intervallen.

Die in dieser Arbeit verwendeten Analysekriterien sind in Tabelle 4 zusammengefasst. Die Tabelle dient als strukturierte Übersicht der Bewertungskategorien und bildet die Grundlage für die spätere Ergebnisdarstellung im Kapitel der Analyseergebnisse.

Nr.	**Analysekriterium**	**Beschreibung**
1	Kommunikationsmechanismen	Analyse der verwendeten Transportprotokolle sowie der Netzwerkcharakteristika der C2-Kommunikation zwischen kompromittiertem System und Server
2	Stealth und Detektierbarkeit	Untersuchung der Sichtbarkeit des Frameworks in einer überwachten Umgebung anhand von Telemetriedaten und Sicherheitsereignissen
3	Modularität	Bewertung der modularen Architektur des Frameworks und der Möglichkeit, einzelne Komponenten flexibel zu konfigurieren
4	Flexibilität der Infrastruktur	Analyse der Anpassungsfähigkeit des Frameworks an unterschiedliche Netzwerkumgebungen, Kommunikationsparameter und Einsatzszenarien

Tabelle 4: Übersicht der verwendeten Analysekriterien

Die gewonnenen Erkenntnisse aus diesen Untersuchungsschwerpunkten bilden die Grundlage für die Bewertung des Frameworks im anschließenden Kapitel der Ergebnisse.

3.5 Ablauf der Experimente

Auf Grundlage der beschriebenen Analyseumgebung und der definierten Analysekriterien werden mehrere aufeinander aufbauende Experimente durchgeführt. Die Experimente orientieren sich an einem vereinfachten Ablauf eines Angriffsszenarios, wie er auch in etablierten Modellen wie der MITRE ATT&CK Knowledge Base beschrieben wird. Dabei wird in dieser Untersuchung nicht die vollständige Angriffskette betrachtet, sondern insbesondere die Phase nach einem bereits vorhandenen Initial Access.

Im vorliegenden Szenario liegt bereits ein gültiger Zugang zu einer virtuellen Desktop-Infrastruktur (VDI) eines Unternehmens vor. Die Untersuchung beginnt daher mit der Analyse, wie aus einer eingeschränkten Benutzerumgebung heraus weitere Systemfunktionen erreicht und anschließend eine Command-and-Control-Infrastruktur etabliert werden kann.

Die Experimente gliedern sich in folgende Untersuchungsschritte:

1. **Analyse der Ausgangsumgebung und Ausbruch aus dem Kiosk-Modus**
   Zu Beginn wird die bereitgestellte VDI-Umgebung untersucht. Diese ist auf einen eingeschränkten Kiosk-Modus beschränkt, in dem lediglich Anwendungen wie Firefox oder WordPad verfügbar sind. Ziel dieses Schrittes ist es, Wege zu identifizieren, um diese Einschränkungen zu umgehen und Zugriff auf eine umfassendere Systemumgebung zu erhalten.

2. **Vorbereitung der Sliver-Infrastruktur**
   Im nächsten Schritt wird die Command-and-Control-Infrastruktur eingerichtet. Hierzu wird der Sliver-Server gestartet und eine Verbindung zwischen dem Operator-Client und der Infrastruktur hergestellt.

3. **Generierung der Sliver-Implantate**
   Anschließend werden Implantate mit unterschiedlichen Kommunikationsparametern generiert. Diese dienen als Payloads zur Etablierung einer Verbindung zwischen dem Zielsystem und dem Command-and-Control-Server.

4. **Übertragung des Implantats auf das Zielsystem**
   Nach erfolgreicher Erweiterung der Zugriffsmöglichkeiten innerhalb der VDI-Umgebung wird untersucht, auf welchem Weg das generierte Implantat auf das Zielsystem übertragen werden kann.

5. **Ausführung des Implantats und Aufbau der C2-Verbindung**
   Nach der Übertragung wird das Implantat auf dem Zielsystem ausgeführt. Dadurch wird eine Verbindung zum Sliver-Server aufgebaut und die Command-and-Control-Kommunikation etabliert.

6. **Analyse der Command-and-Control-Kommunikation**
   Im Anschluss wird die Kommunikationsverbindung zwischen dem kompro-

mittierten System und dem C2-Server untersucht. Dabei werden insbesondere Kommunikationsmuster sowie genutzte Transportprotokolle analysiert.

7. **Netzwerkanalyse mit Wireshark**
   Der erzeugte Netzwerkverkehr wird mithilfe von Wireshark analysiert, um Paketstrukturen, Verbindungsintervalle und mögliche Auffälligkeiten der C2-Kommunikation zu identifizieren.

8. **Analyse der Telemetriedaten im Elastic Security Dashboard**
   Parallel dazu werden die während der Experimente erzeugten Prozess- und Netzwerkereignisse im Elastic Security Dashboard ausgewertet, um mögliche Detektionen oder sicherheitsrelevante Ereignisse zu identifizieren.

9. **Variation der Kommunikationsparameter**
   Abschließend werden verschiedene Konfigurationsparameter des Frameworks angepasst, beispielsweise Beacon-Intervalle oder verwendete Transportprotokolle, um deren Einfluss auf Kommunikationsverhalten und Detektierbarkeit zu untersuchen.

Die praktische Durchführung dieser Experimente sowie die dabei gewonnenen Beobachtungen werden im folgenden Kapitel detailliert dargestellt.

4 Durchführung - Analyse des Sliver Frameworks

4.1 Aufbau der Testumgebung

4.2 Einrichtung der Sliver Infrastruktur

4.3 Erstellung und Ausführung von Implantaten

4.4 Analyse der C2 Kommunikation

4.5 Analyse der Systemartefakte

4.6 Analyse der Detektion durch Elastic

4.7 Variation der Kommunikationsparameter

5 Ergebnisse

tabelle 4 nochmal einfügen

6 Diskussion

6.1

7 Fazit

8 Ausblick

Literatur

[1] „Was ist Cyber Kill Chain? — Microsoft Security“, besucht am 18. Feb. 2026. Adresse: https://www.microsoft.com/de-de/security/business/security-101/what-is-cyber-kill-chain.

[2] „Was ist C2? Command-and-Control-Infrastruktur erklärt — Varonis“, besucht am 19. Feb. 2026. Adresse: https://www.varonis.com/de/blog/was-ist-c2.

[3] „Getting started“, GitHub, besucht am 27. Feb. 2026. Adresse: https://github.com/BishopFox/sliver/wiki/Getting-Started.

[4] „Heuristic detection“, Multilogin, besucht am 27. Feb. 2026. Adresse: https://multilogin.com/glossary/heuristic-detection/.

[5] „Modules“, Metasploit Documentation Penetration Testing Software, Pen Testing Security, besucht am 24. Feb. 2026. Adresse: https://rapid7.github.io/metasploit-framework/docs/modules.html.

[6] „Professional lab scenarios — hack the box help center“, besucht am 11. März 2026. Adresse: https://help.hackthebox.com/en/articles/5229167-professional-lab-scenarios.